

Eng 3.5. Network Device Hardening

Task 1 - Introduction

Network devices are the building blocks and backbone of today's contemporary and large-scale networks and systems. The role of network devices is to ensure reliable and efficient transfer, filtering, and management of data across or within networks. Many network devices range from basic layer one hubs or repeaters to layer two switches, layer three routers, load balancers, virtual private networks, and intrusion prevention systems.

Task 2 - Common Threat and Attack Vectors

Before proceeding with our actual topic, it is imperative to understand the difference between network devices and endpoint devices. Endpoint devices refer to any device that can generate or consume data on a network, such as Laptops, Desktops, Smartphones, Tablets, Printers, Servers, and IoT Devices. They are typically located at the edge of a network and interact directly with users.

Threat	Description	Attack Vector
Unauthorised access	Gain unauthorised control of a network device, and then the complete network.	• Password attacks (brute force, dictionary & hybrid) • Exploit known vulnerabilities, e.g. RCE • Social Engineering/Phishing attack to trick network administrators into disclosing sensitive information such as usernames and passwords of devices
Denial of Service (DoS)	Disruption of critical devices and services to make them unavailable to genuine users.	• Flooding devices with fake requests • Exploiting vulnerabilities in logical or resource handling • Manipulating network packets

Man-in-the-Middle Attacks	Intercept the network requests between two parties by masquerading as each other to steal sensitive information or alter/manipulate the requests.	• ARP spoofing • DNS spoofing • Rogue access points
Privilege escalation	Gaining higher-level privileges or rights to perform restricted actions, e.g. accessing sensitive information or executing malicious code.	• Weak passwords or use of the same passwords for user and admin accounts • Exploiting vulnerabilities • Misconfigurations
Bandwidth theft/ hotlinking	Linking a bandwidth-intensive resource (image or video) from an external website to its original website, without permission. This can cause increased traffic to the original website.	• Scraping large volumes of data • DoS attacks • Malware attacks

Answer the questions below

The device that is used to control and manage network resource is called?

Network device

A threat vector that includes disruption of critical devices and services to make them unavailable to genuine users is called?

Denial of Service

Task 3 - Common Hardening Techniques

- **Updating & Patching:** Ensuring the latest version of the Operating System and underlying applications of all devices and systems and installing regular security patches is the core hardening measure. Outdated OS and applications contain vulnerabilities that attackers can exploit.
- **Disabling unnecessary services & ports:** Turn off all unnecessary services and block all ports (physical and virtual) that are not needed for system

functionality. This will reduce the attack surface by minimising the number of entry points an attacker can exploit.

- **Principle of Least Privilege (POLP):** Restrict users and processes to only the minimum necessary permissions required to perform their functions.
- **Logs Monitoring:** Implement a log monitoring system to monitor for unusual activity or security events.
- **Backup regularly:** Take routine backups of systems and configurations as they can help recover from a security incident or system failure.
- **Enforcing Strong Passwords:** Change default login passwords and use strong passwords that are at least ten characters long with a combination of small letters, capital letters, special characters, and numbers. These types of passwords protect against dictionary and brute-force attacks.
- **Multi-Factor Authentication (MFA):** MFA is an additional security layer requiring two or more types of identification before accessing the account or system. The two factors are generally something we know (like passwords) and something we have (like biometrics).

Importance of Secure Protocols: They ensure that sensitive data transmitted between devices is encrypted and cannot be intercepted by malicious actors. Moreover, secure protocols also help prevent man-in-the-middle attacks and other network-based exploits. Using secure protocols, network administrators can ensure that only authorised personnel can access sensitive information and perform system administration tasks. Necessary security protocols include HTTPS, SSH, SSL/TLS, and IPsec.

Removal/Blocking of Insecure Protocols: In addition to using secure protocols, removing and blocking access to those insecure protocols is equally essential, which will decrease an attacker's attack surface. Most important are the protocols that transmit data in clear text without encrypting them, like FTP, HTTP, Telnet, SMTP, and more. Moreover, there are inherently secure protocols (e.g. LDAP, RDP, SIPS); however, they can allow attackers to exploit the network if configured incorrectly.

Implementation of Monitoring and Logging Controls: Logging in network devices is essential for detecting and investigating security incidents, identifying

performance issues, and complying with regulatory requirements. It provides a record of events and activities on the device, which can be used for troubleshooting, forensic analysis, and auditing purposes. The following techniques are generally used for logging:

- **Syslog:** A protocol to standardise the transfer of log messages, with the purpose of storing and analysing log messages to a central server.
- **SNMP:** Traps a notification sent by a network device to a management system when a predefined event occurs.
- **NetFlow:** A protocol used to collect and analyse network traffic data for monitoring and security analysis.
- **Packet Captures:** Capturing network traffic and storing it for analysis using a tool like Wireshark.

Answer the questions below

Suppose you are configuring a router; which of the following could be considered an insecure protocol:

- A: HTTPS
- B: FTP *
- C: SSH
- D: IPsec

The protocol for sending log messages to a centralised server for storage and analysis is called?

Syslog

Task 4 - Hardening Virtual Private Networks

Virtual private networks (VPNs) are now needed in the age of remote work and online communication to protect sensitive data and preserve privacy. Yet, hardening VPNs is crucial to ensure their efficiency as cyberattacks continue to develop. Hardening VPNs entails adopting additional security measures, such as multi-factor authentication and encryption techniques, to make it more challenging for hackers to access the network. By taking these extra precautions,

businesses can better safeguard their data and defend against cyberattacks, raising their security level and bringing them more peace of mind.

Standard Hardening Practices: Usually, all the VPN servers consist of server-side and client-side configurations through a standard config file. System administrators must understand the file's content and edit it as per best security practices.

- The OpenVPN server config file is located at `/etc/openvpn/server/server.conf`. Once the machine is loaded, open the terminal and load the file by issuing the command `sudo nano /etc/openvpn/server/server.conf`.
- Once you made the desired changes in the file, press `Ctrl+O` and hit `Enter`, then press `Ctrl+X` to exit.
- The command `sudo systemctl restart openvpn-server@server.service` can restart the OpenVPN service.

Moving forward, the following are some of the significant hardening practices for a VPN server:

- **Use strong encryption algorithm:** Configure the VPN gateway to use strong encryption to protect data in transit. The **cipher** directive in the config file can be used to select the encryption scheme. The possible options for `cipher` ([opens in new tab](#)) include AES, Blowfish, Camellia, and more. For example, **AES-128-CBC** mode means to use the AES encryption algorithm with a key size of 128-bit in Cipher Block Chaining (CBC) mode, as seen below. **AES-256-CBC** is typically considered one of the strongest cipher encryption nowadays.

```
thm@machine$ sudo nano /etc/openvpn/server/server.conf
local MACHINE_IP
port 1194
proto udp
dev tun
ca ca.crt
cert server.crt
key server.key
cipher AES-128-CBC #cipher options can be modified
```

```
dh dh.pem
auth SHA256 tls-crypt tc.key
topology subnet
```

- **Keep VPN gateway software up-to-date:** Ensure that the VPN gateway software is always updated with the latest security patches and updates. Every VPN software has a different method for it. You can use `sudo apt upgrade openvpn` to update OpenVPN (please note that the attached VM does not have an internet connection).
- **Implement strong authentication:** Use strong authentication mechanisms such as a combination of Transport Layer Security (TLS) and a secure hashing algorithm. We can use the `auth` directive to specify the exact algorithm in the OpenVPN configuration file to ensure that a secure hashing algorithm will be used for packet authentication. Some of the [options\(opens in new tab\)](#) for `auth` directive are **SHA1, SHA128, SHA256, SHA512 and MD5**. You can set the `auth` directive through the following command:

```
thm@machine$ sudo nano /etc/openvpn/server/server.conf
local MACHINE_IP
port 1194
proto udp
dev tun
ca ca.crt
cert server.crt
auth SHA256 #use this to change the auth parameter
tls-crypt tc.key
topology subnet
```

- **Change default settings:** Change the default usernames and passwords to something unique to reduce the risk of unauthorised access to the VPN gateway.
- **Enable Perfect Forward Secrecy (PFS):** Perfect Forward Secrecy (PFS) in OpenVPN generates unique session keys for each session to strengthen the security of the VPN connection. Because of this, even if a hacker successfully obtained a session key, they could not use it to decode more sessions. For

each session, PFS generates a new set of encryption keys, preventing the possibility of remotely decrypting previously acquired material. As a result, it is far more challenging for an attacker to spoof the VPN connection and steal sensitive data. We can use the `tls-crypt` directive in the OpenVPN configuration file to enable PFS. The `tls-crypt` directive requires a key that can be generated using the command `sudo openvpn --genkey --secret my.key` and should be placed in the same directory on the server. Choosing the appropriate cipher and auth, like **cipher AES-256-CBC** and **auth SHA 256**, supports PFS if combined with `tls-crypt`. The exact configuration is mentioned below:

```
thm@machine$ sudo nano /etc/openvpn/server/server.conf
local MACHINE_IP
port 1194
proto udp
dev tun
ca ca.crt
cert server.crt
cipher AES-256-CBC
auth SHA256
tls-crypt my.key #use this to change the tls-crypt parameter
tls-version-min 1.2 #use this to change the TLS version
topology subnet
```

- **Dedicated Users for VPN Server:** Limit user access by creating a dedicated user account and group with restricted permissions specifically for running the OpenVPN server.

Answer the questions below

Update the config file to use cipher AES-128-CBC. What is the flag value linked with the cipher directive?

THM{CIPHER_UPDATED_1101}

Update the config file to use auth SHA512. What is the flag value linked with the auth directive?

THM{AUTH_UPDATED_123}

```
ubuntu@tryhackme: ~  
File Edit View Search Terminal Help  
local 10.0.1.1 //change that to your local machine IP  
port 1194  
proto udp  
dev tun  
ca ca.crt  
cert server.crt  
key server.key  
dh dh.pem  
auth SHA256 #Flag value: THM{AUTH_UPDATED_123}  
tls-crypt tc.key  
tls-version-min 1.2  
topology subnet  
server 10.8.0.0 255.255.255.0  
push "redirect-gateway def1 bypass-dhcp"  
ifconfig-pool-persist ipp.txt  
push "dhcp-option DNS 1.1.1.1"  
push "dhcp-option DNS 1.0.0.1"  
push "block-outside-dns"  
keepalive 10 120  
cipher AES-256-CBC #Flag value: THM{CIPHER_UPDATED_1101}  
user nobody  
group nogroup  
persist-key  
persist-tun  
verb 3  
crl-verify crl.pem  
explicit-exit-notify  
~  
~
```

As per the config file, what is the port number for the OpenVPN server?

1194

Task 5 - Hardening Routers, Switches & Firewalls

Routers and switches must be hardened for the network infrastructure to be secure and reliable. Every network needs routers and switches, often the first line of defence against potential security risks and attacks. By hardening these devices, we can lower the possibility of unauthorised access, avoid data breaches, and ensure network service availability. Improved network performance, increased resilience against cyberattacks, and regulatory compliance are a few of the main advantages of hardening routers and switches.

Routers and switches without enough hardening are susceptible to various attacks, including denial of service and network profiling.

Recommended Hardening Routers, Switches & Firewalls Techniques:

- **Setting up the device:** While setting up any network device, it is necessary to fill in all relevant details like hostname, timezone, logging, and more. These features assist in conducting incident handling in case of a compromise. For example, logging must be enabled to log all the events with the default alert level **Debug**. Similarly, timezone and time synchronisation must be set accurately to properly correlate events with their occurrence time. You can enable and modify these settings through **System > System** and select the desired option.

The screenshot shows the OpenWrt web interface. At the top, there's a navigation bar with 'f481ecfc7c66', 'Status', 'System' (highlighted with a yellow box), 'Network', and 'Logout'. A 'REFRESHING' button is on the right. Below the navigation bar, the 'System' section is titled, followed by a subtitle: 'Here you can configure the basic aspects of your device like its hostname or the timezone.' Under 'System Properties', there are four tabs: 'General Settings' (highlighted with a yellow box), 'Logging', 'Time Synchronization', and 'Language and Style'. The 'General Settings' tab contains several fields: 'Local Time' with a date/time input '2023-03-29 09:43:22' and two buttons 'Sync with browser' and 'Sync with NTP-Server'; 'Hostname' with a text input 'OpenWrt'; 'Description' with a text input and a help icon; 'Notes' with a text area and a help icon; and 'Timezone' with a dropdown menu set to 'UTC'. At the bottom right, there are three buttons: 'Save & Apply' (highlighted with a yellow box), 'Save', and 'Reset'.

- **Change default credentials:** Usually, the admin web interface is protected through a username and password, and people tend to ignore changing the default. A threat actor can access the router's admin interface and compromise the whole network using default credentials. We can change the default password in OpenWrt through **System > Administration**, enter a new password, and click the **Save** button.

9d73f431d362 Status ▾ **System ▾** Network ▾ Logout

No password set!
There is no password set on this router. Please configure a root password to protect the web interface.

[Router Password](#) [SSH Access](#) [SSH-Keys](#)

Router Password

Changes the administrator password for accessing the device

Password *

Confirmation *

? Password strength: **Medium**

Save

- Enable secure network protocols:** For a network device to maintain the confidentiality, integrity, and availability of network traffic, secure protocols must be enabled. Secure protocols like HTTPS, SSH, and SSL/TLS offer encrypted authentication mechanisms and communications to stop unauthorised access and eavesdropping. By enabling secure protocols on a router, you can reduce the risk of data breaches, man-in-the-middle attacks, and other security threats. You can enable SSH in OpenWrt through [System > Administration > SSH Access](#), then select the interface and port number and click [Save & Apply](#). Moreover, you can also add specific public SSH-Keys for passwordless login.

f481ecfc7c66
System
Network
Logout

Router Page
SSH Access
SSH-Keys

SSH Access

Dropbear offers [SSH](#) network shell access and an integrated [SCP](#) server

Dropbear Instance

Interface
unspecified

? Listen only on the given interface or, if unspecified, on all

Port
22

Password authentication
☒

? Allow [SSH](#) password authentication

Allow root logins with password
☒

? Allow the *root* user to login with password

Gateway Ports
☐

? Allow remote hosts to connect to local SSH forwarded ports

Add instance

3

Save & Apply

Save

Reset

- Disabling unnecessary scripts:** Almost every network device executes some startup scripts to provide a better user experience to a user. For example, crontab is executed on startup to verify and execute any cron job. Threat actors try to gain persistent access on a network device by adding their malicious scripts on the startup. We can add/remove startup scripts and set the priority through `System > Startup` .

f481ecfc7c66
Status ▾
System ▾
Network ▾
Logout

Startup

Initscripts
Local Startup

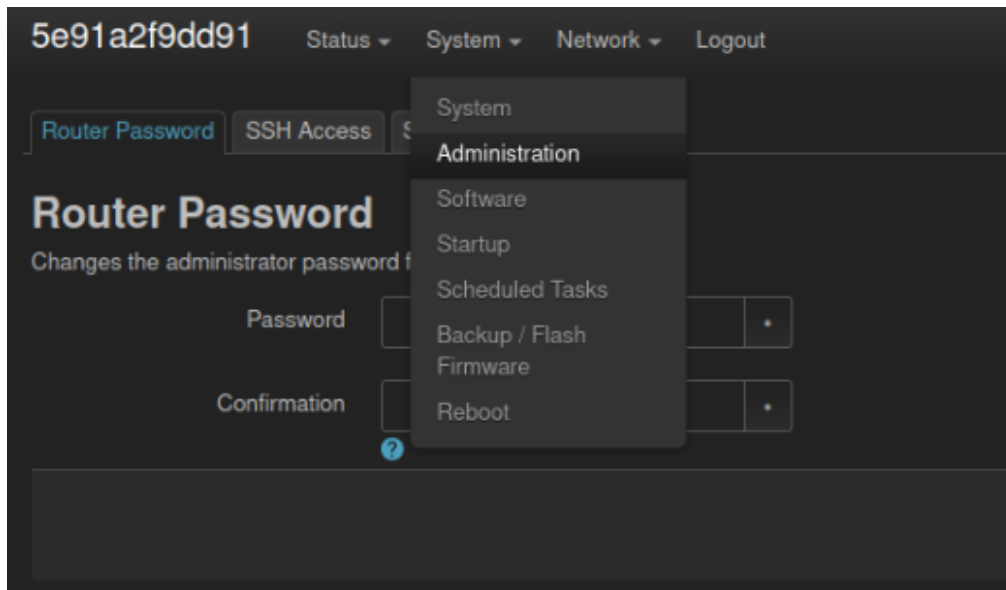
You can enable or disable installed init scripts here. Changes will applied after a device reboot.
Warning: If you disable essential init scripts like "network", your device might become inaccessible!

Start priority	Initscript				
00	urngd	Enabled	Start	Restart	Stop
00	sysfixtime	Enabled	Start	Restart	Stop
10	system	Enabled	Start	Restart	Stop
10	boot	Enabled	Start	Restart	Stop
11	sysctl	Enabled	Start	Restart	Stop
12	log	Enabled	Start	Restart	Stop
12	rpcd	Enabled	Start	Restart	Stop
19	dropbear	Enabled	Start	Restart	Stop
19	firewall	Enabled	Start	Restart	Stop

- Securing Wi-Fi:** If the router has Wi-Fi capabilities, securing the Wi-Fi by enabling strong encryption like WPA2/WPA3, disabling SSID broadcast, changing default passwords, and more.

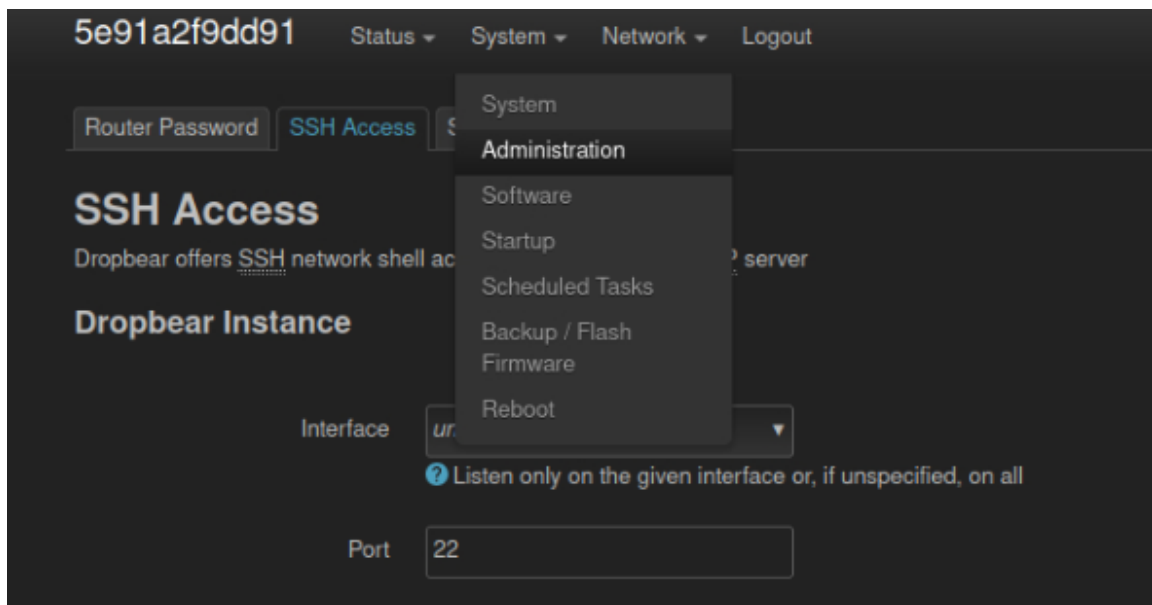
Answer the questions below

Update the password of the router to TryHackMe123.



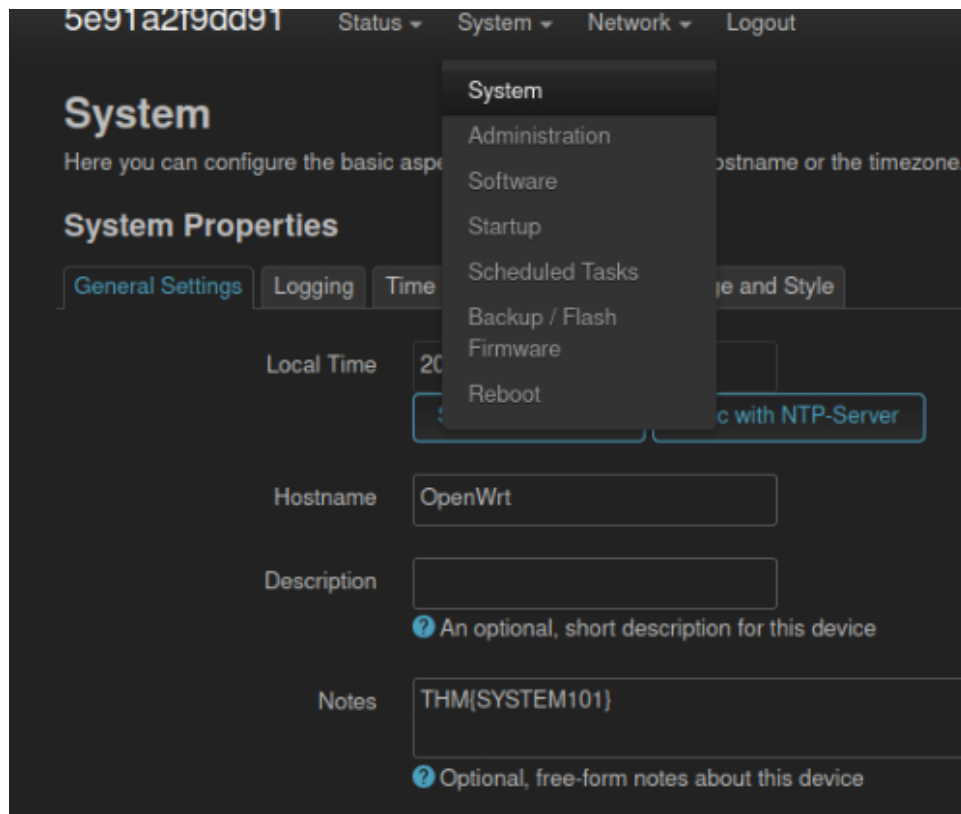
What is the default SSH port configured for OpenWrt in the attached VM?

22



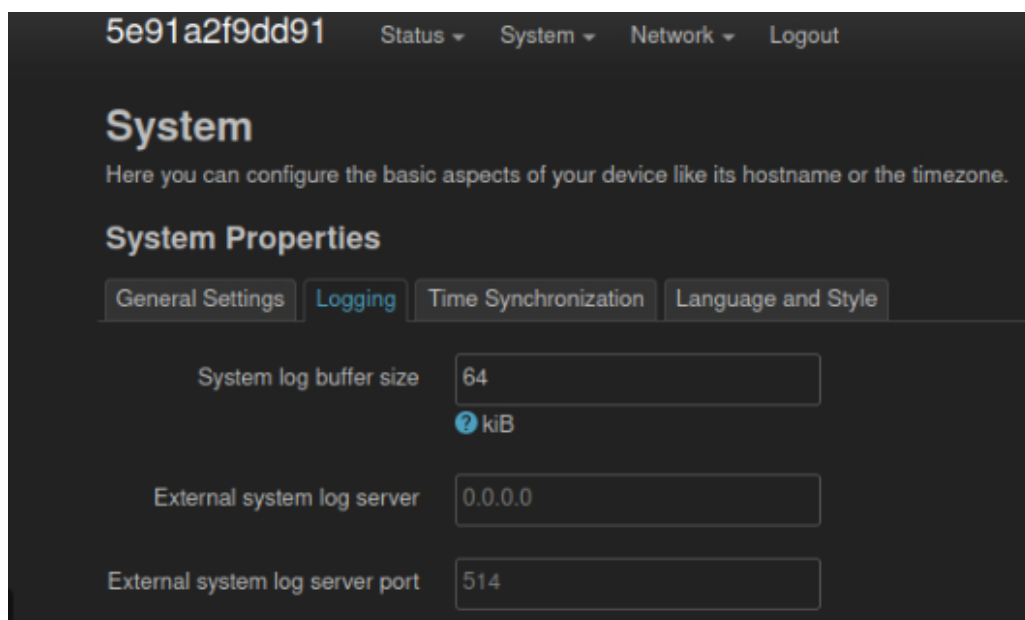
Go through the General Settings option under the System tab in the attached VM. The administrator has left a special message in the Notes section. What is the flag value?.

THM{SYSTEM101}



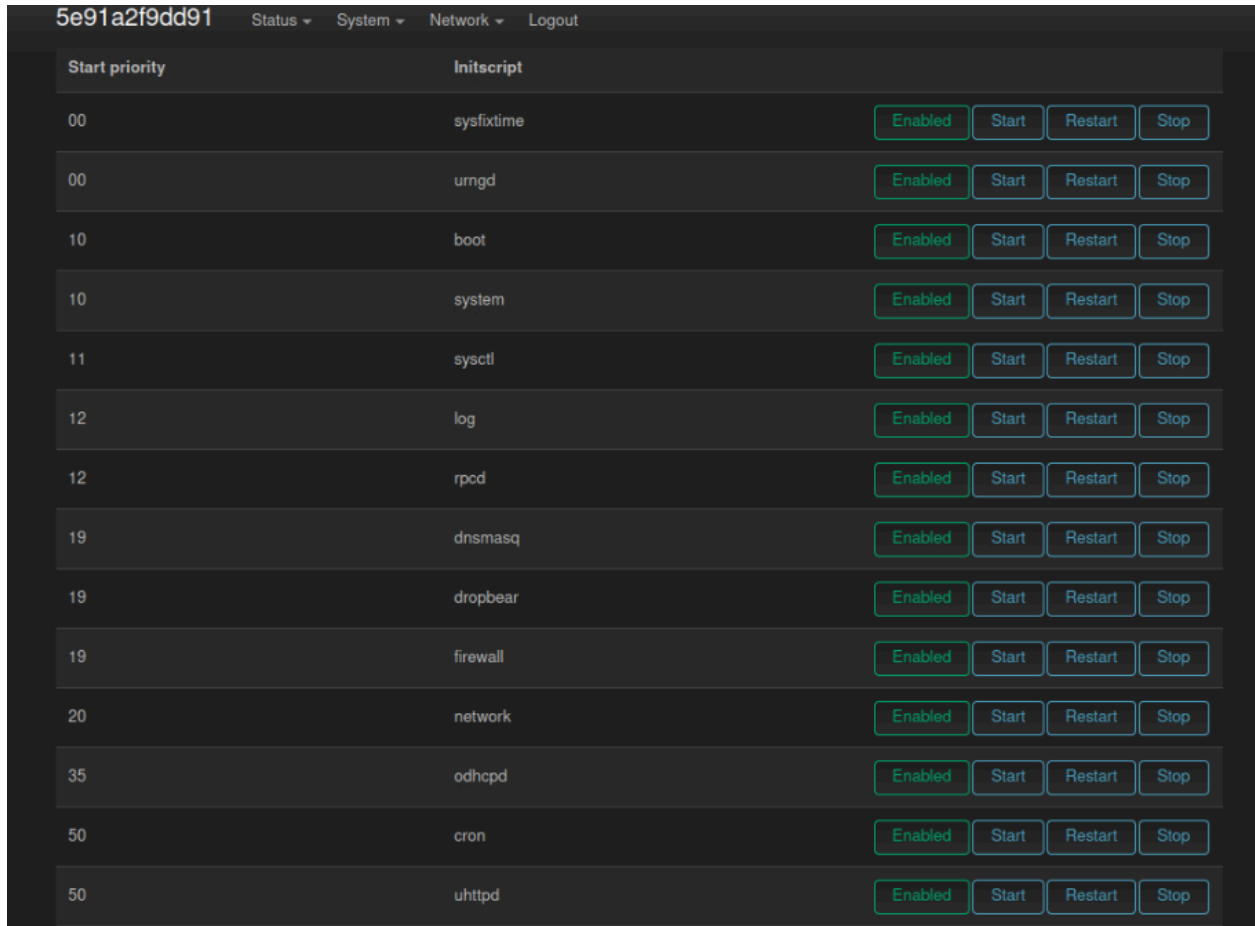
What is the default system log buffer size value for the OpenWrt router in the attached VM?

64



What is the start priority for the script uhttpd?

50



The screenshot shows a web interface for a network device with a dark theme. At the top, there is a header bar with the device ID '5e91a2f9dd91' and navigation links for 'Status', 'System', 'Network', and 'Logout'. Below this is a table listing various services. The table has two main columns: 'Start priority' and 'Initscript'. Each row represents a service and includes an 'Enabled' status button and three action buttons: 'Start', 'Restart', and 'Stop'. The services are listed in ascending order of their start priority.

Start priority	Initscript	Enabled	Start	Restart	Stop
00	sysfixtime	Enabled	Start	Restart	Stop
00	urngd	Enabled	Start	Restart	Stop
10	boot	Enabled	Start	Restart	Stop
10	system	Enabled	Start	Restart	Stop
11	sysctl	Enabled	Start	Restart	Stop
12	log	Enabled	Start	Restart	Stop
12	rpcd	Enabled	Start	Restart	Stop
19	dnsmasq	Enabled	Start	Restart	Stop
19	dropbear	Enabled	Start	Restart	Stop
19	firewall	Enabled	Start	Restart	Stop
20	network	Enabled	Start	Restart	Stop
35	odhcpd	Enabled	Start	Restart	Stop
50	cron	Enabled	Start	Restart	Stop
50	uhttpd	Enabled	Start	Restart	Stop

Task 6 - Hardening Routers, Switches & Firewalls - More Techniques

- **Manage traffic rules:** Network devices allow you to create and implement traffic rules that accept/deny network traffic. For example, we notice that the data of users connected with our network device is being exfiltrated to a command and control server IP address. We can create a rule to block all traffic where the destination IP matches the attacker's command and control server. We can add/edit traffic rules through `Network > Firewall > Traffic Rules`, and click `Add` to create a new rule.

f481ecfc7c66
Status
System
Network
Logout
UNSAVED CHANGES: 6

General Settings
Port Forwards
Traffic Rules
NAT Rules
Custom Rules

Firewall - Traffic Rules

Traffic rules define policies for packets traveling between different zones, for example to reject traffic between certain hosts or to open WAN ports on the router.

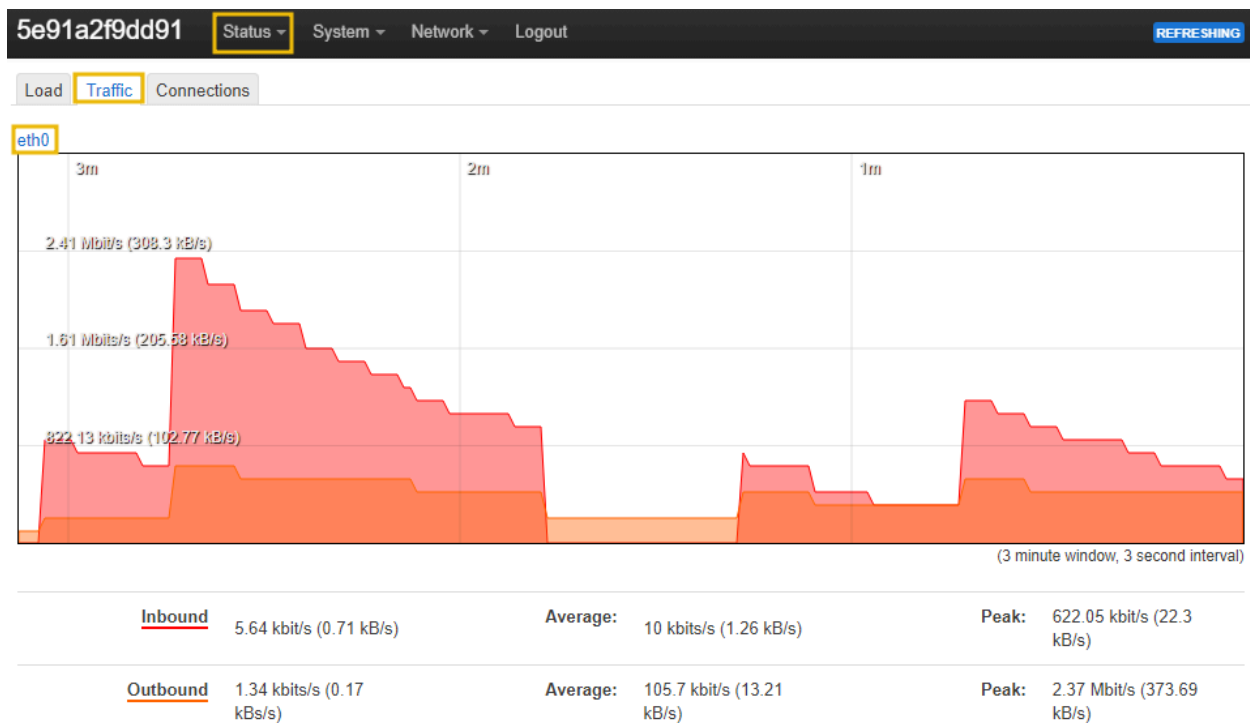
Traffic Rules

Name	Match	Action	Enable	
Allow-DHCP-Renew	Incoming <i>IPv4</i> , protocol <i>UDP</i> From wan To this device, port 68	Accept input	☒	Edit Delete
Allow-Ping	Incoming <i>IPv4</i> , protocol <i>ICMP</i> From wan To this device	Accept input	☒	Edit Delete
Allow-IGMP	Incoming <i>IPv4</i> , protocol <i>IGMP</i> From wan To this device	Accept input	☒	Edit Delete
Allow-DHCPv6	Incoming <i>IPv6</i> , protocol <i>UDP</i> From wan To this device, port 546	Accept input	☒	Edit Delete

Add

Save & Apply
Save
Reset

- Monitor traffic:** As a network administrator, keeping track of network traffic, like uploads and downloads of data at different intervals, is essential. For example, you have excessive data uploaded from one of the email servers to an unknown IP address. Such alerts enable you to take remedial measures and stop data pilferage timely. Usually, network devices provide real-time graphs to monitor the traffic. We can view real-time traffic statistics through [Status > Realtime Graph > Traffic](#) .



- **Configuring port forwarding:** A firewall's port forwarding capability enables inbound traffic from the internet or other sources to be routed to a particular device or service on the internal network. The firewall can send incoming traffic to the appropriate device or service on the internal network by establishing port forwarding rules while blocking any other incoming traffic that does not comply with the rules. This feature helps host applications that need outside access, granting remote control of internal devices. Port forwarding should be used carefully because it can expose internal devices and services to potential security issues if improperly secured and configured. Threat actors could add new rules here for creating connections to external command and control servers. We can configure port forwarding through **Network > Firewall > Port Forwards**, and click the **Add** button.

5e91a2f9dd91 Status ▾ System ▾ **Network ▾** Logout

General Settings **Port Forwards** Traffic Rules NAT Rules Custom Rules

Firewall - Port Forwards

Port forwarding allows remote computers on the Internet to connect to a specific computer or service within the private LAN.

Port Forwards

Name	Match	Action	Enable
This section contains no values yet			

Add

Save & Apply ▾ **Save** **Reset**

- **Monitoring scheduled tasks:** It is important to monitor scheduled tasks to confirm that the original scheduled tasks lists are not modified by a threat actor. To add or remove scheduled tasks, which in our case are handled by cron, navigate to **System > Scheduled Tasks**, add the new cron job, and click **Save**. You can learn how to create cron jobs [here](#)(opens in new tab).

f481ecfc7c66 Status ▾ **System ▾** Network ▾ Logout

Scheduled Tasks

This is the system crontab in which scheduled tasks can be defined.

```
0 0 * * * reboot
```

- **Update firmware:** It is essential to update the firmware and installed packages on a regular basis to avoid any know/unknown attacks. We can update the firmware through **System > Software**.

f481ecfc7c66
Status ▾
System ▾
Network ▾
Logout

Software

Free space:
65% (40.8 GB)

Filter:
Clear
Download and install package:
OK
Actions:

Available
Installed
Updates

«
Displaying 1-100 of 9503
»

Package name	Version	Size (.ipk)	Description	
464xlat	12	4.9 KB	464xlat provides support to deploy limited IPv4 access services to mobile...	Install...
6in4	26	2.5 KB	Provides support for 6in4 tunnels in /etc/config/network....	Install...
6rd	10	3.7 KB	Provides support for 6rd tunnels in /etc/config/network....	Install...
6to4	13	1.9 KB	Provides support for 6to4 tunnels in /etc/config/network....	Install...
UDPSpeeder	20210116.0-2	77.7 KB	A Tunnel which Improves your Network Quality on a High-latency Lossy Link by using Forward Error Correction, for All Traffics(TCP/UDP/ICMP)	Install...

Additional Techniques in an Enterprise Environment:

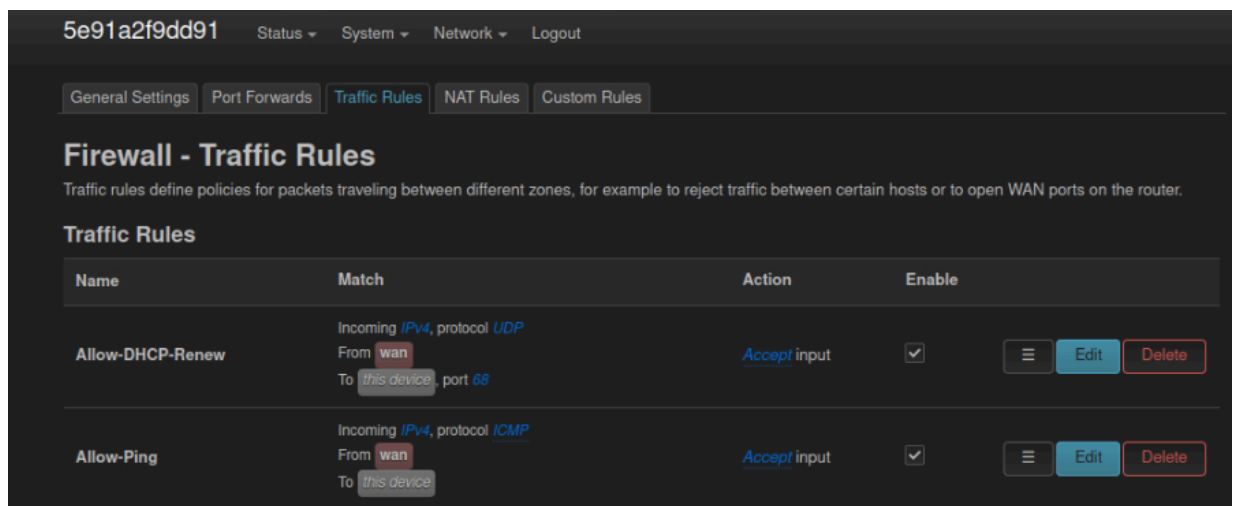
- Configuring port security:** This includes limiting the number of MAC addresses registered on a switch port and taking particular action whenever unauthorised access is detected. Enabling port security enables an administrator that data is coming from a valid source and will be forwarded to a legitimate receiver.
- Preventing ARP spoofing:** ARP spoofing is one of the most common vectors for launching man-in-the-middle attacks on the network. The threat can be mitigated by enabling static ARP tables and implementing MAC address filtering.
- Preventing rogue DHCP servers:** The attacker creates a spoofed DHCP server that can be later on used for assigning IPs to clients and launching MITM attacks. Mitigation measures to prevent such attacks include configuring static DHCP binding and ensuring no unknown devices are added to a network through network mapping tools.

- **Enabling IPv6:** Unlike IPv4, IPv6 has built-in support of IPsec that can be used to secure network communication and provide confidentiality, integrity, and authenticity. Moreover, this will help in protection against MITM, eavesdropping, and tampering of packets in transit.

Answer the questions below

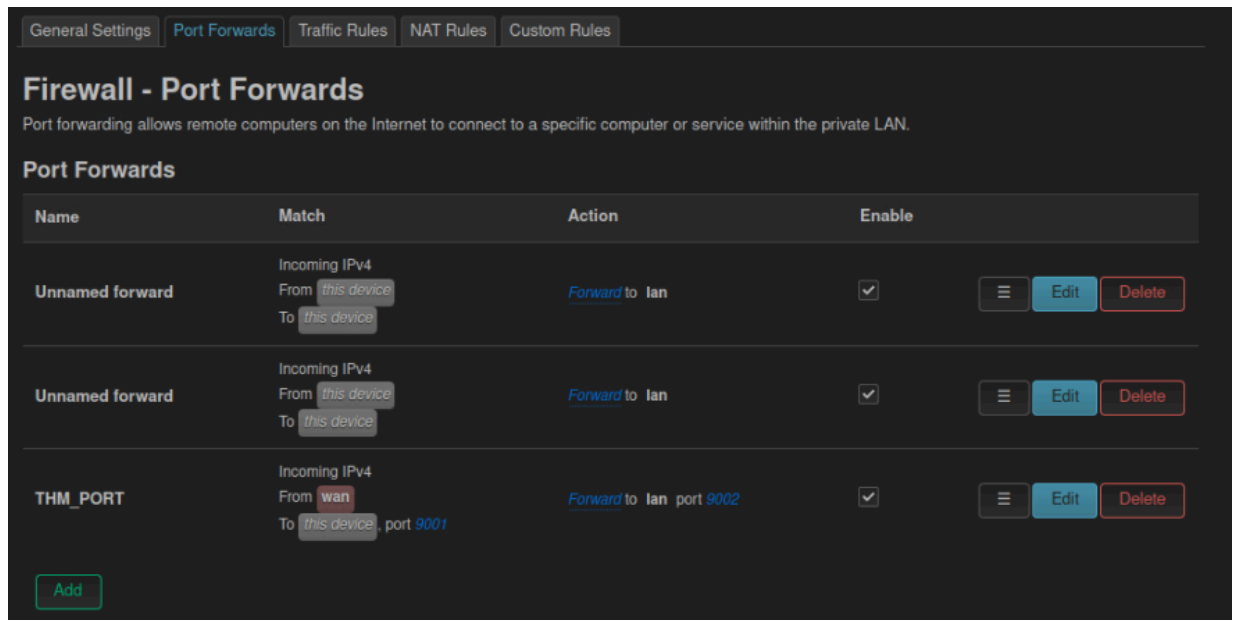
What is the name of the rule that accepts ICMP traffic from source zone WAN and destination zone as this device?

Allow-Ping



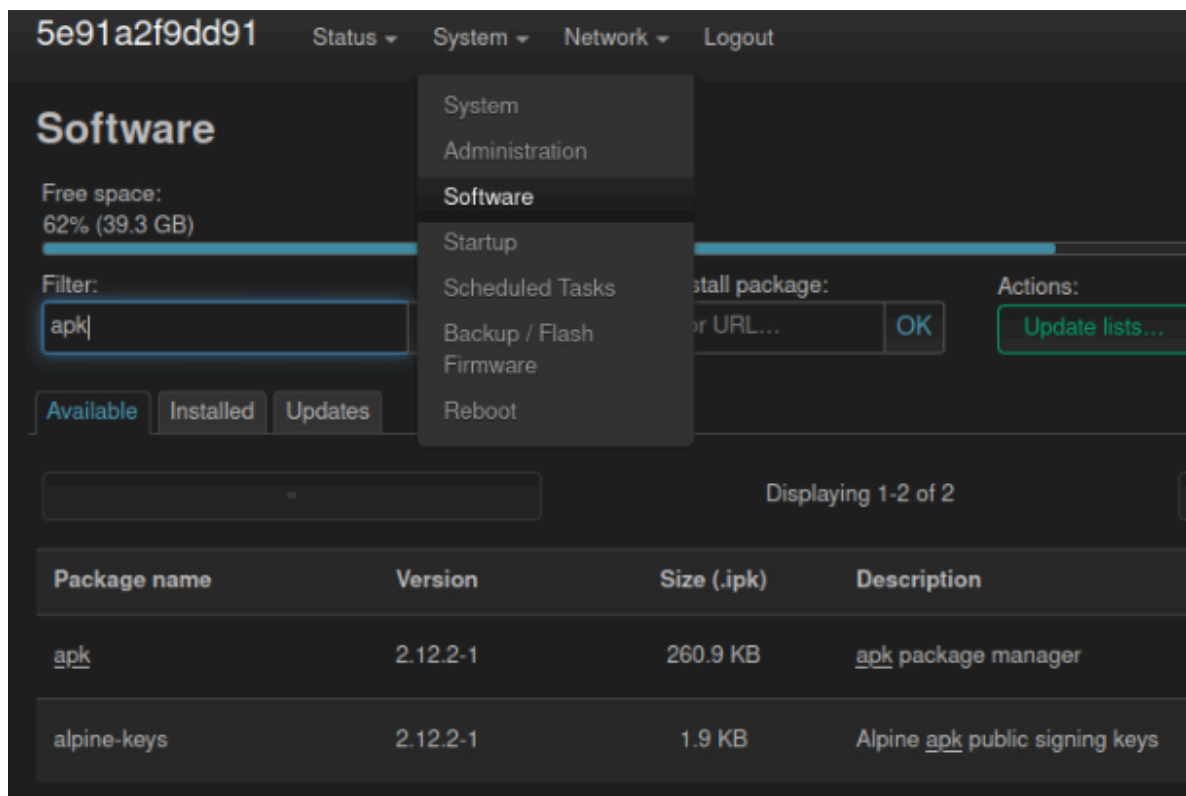
What is the name of the rule that forwards data coming from WAN port 9001 to LAN port 9002?

THM_PORT



What is the version number for the available apk package?

2.12.2-1



Task 7 - Important Tools for Network Monitoring

Tool	Usage Description
<u>Nagios(opens in new tab)</u>	A popular open-source software for monitoring systems, networks, and infrastructure. It provides real-time monitoring and alerting for various services and applications.
<u>SolarWinds Network Performance Monitor(opens in new tab)</u>	A comprehensive network monitoring tool that provides real-time visibility into network performance and availability. It includes network mapping, automated network discovery, and customisable dashboards.
<u>PRTG(opens in new tab)</u>	An all-in-one network monitoring tool that provides comprehensive performance and availability monitoring. It includes real-time traffic analysis, custom dashboards, and customisable alerts.
<u>Zabbix(opens in new tab)</u>	A powerful open-source network monitoring tool that provides real-time network performance and availability monitoring. It includes features such as customisable dashboards, network mapping, and alerting.

Answer the questions below

| Are network monitoring tools capable of detecting bandwidth bottlenecks?

yea